Universidad Nacional de Loja

Facultad de la Energía, las Industrias y los Recursos Naturales No Renovables

Carrera de Computación

ACD 4 — Modelo de amenazas y revisión de seguridad

Desarrollo Basado en Plataformas

AUTOR:

Miguel Armas, Soledad Buri, Richard Chamba, Odalis Rosillo, Emilio Flores

TUTOR:

Edison Leonardo Coronel Romero

Loja, Ecuador

Declaración de Delegación a IA Generativa

Se utilizó ChatGPT/Codex para inspección de fuentes, consulta oficial y preparación de documentos, tests y configuración propuestos. No se ejecutó código del target, no hay parche funcional o despliegue nuevos ni participación/aceptación humana atribuida.

Declaración enviada por: Miguel Armas, Soledad Buri, Richard Chamba, Odalis Rosillo, Emilio Flore

Índice General

Declaración de uso de IA Generativa **1**

1 1. Incremento, activos y fronteras **4**

2 2. Revisión de controles y amenazas **5**

2.1 Autenticación 5

2.2 Autorización 5

2.3 Validación sintáctica y de negocio 5

2.4 Errores, secretos y configuración 6

2.5 Mitigación y priorización 7

3 3. Clínica, evidencias y ajustes **8**

A Incremento SIGEAC — Activos, amenazas y controles **10**

A.1 Activos y confianza 10

A.2 Escala de planificación 11

A.3 Matriz de amenazas 12

A.4 Permisos comprobables por capacidad y ámbito 15

B Hallazgos académicos, controles y trazabilidad — Semanas 4–5 **17**

B.1 Matriz SDD 19

B.2 Inventario de verificación a ejecutar en sandbox conforme 20

B.3 Correcciones y revisión cruzada 22

C Fuentes compartidas — Semanas 4 y 5 **23**

C.1 Evidencia del repositorio 23

C.2 Referencias oficiales consultadas 25

C.3 Ejecución y límites 27

Semana 4 · Actividad grupal con evidencia individual · SIGEAC / SEC-UNL.

Integrantes y fecha de sesión pendientes. Asignatura/docente se toman como referencia de APE4, Desarrollo Basado en Plataformas / Edison Leonardo Coronel Romero, sujetos a confirmar para esta ACD. No se declara una sesión ni revisión cruzada realizada.

1. 1. Incremento, activos y fronteras

Se revisan los dos flujos de Semana 3: catálogo con historial y preparación/consulta de proceso, con identidad, autorización y auditoría como dependencias. Requisitos: AA-RF-01–14, AA-RNF-01–03/05–07/09/10 y los AC/VC del dossier AA2. C4 y OpenAPI provienen de APE3. El backend real es Spring Boot, no DRF; sobre universal y decisión tecnológica siguen pendientes.

La matriz de amenazas define ocho activos A-01–08, seis fronteras F-01–06, ocho amenazas T-01–08 y una observación protocolaria T-09, razones de impacto y permisos. Debe leerse como parte de este informe. Protege cuentas/credenciales, sesión/CSRF, catálogo, procesos, auditoría, configuración, recursos y artefactos. Los documentos/evidencias del producto completo quedan fuera de los endpoints seleccionados; no se presupone inexistencia global ni ausencia de riesgo en ellos.

Superficies: POST sessions, rutas protegidas de carreras/unidades/procesos/modelos, UUID/path, filtros de búsqueda/página, JSON, cookies, CSRF, If-Match/ETag, configuración env y DB. Swagger aparece permitido por el filtro, pero el perfil prod deshabilita sus endpoints: no se acusa exposición productiva a partir de una regla aislada. Recuperación de cuenta, uploads y servicios externos no se fuerzan en este modelo sin operación del recorte que los justifique.

Personas sin sesión no obtienen recursos protegidos; lectores tienen ámbito; administración de catálogo no concede gestión de proceso ni autoridad institucional. Las cuentas técnicas se rechazan para operaciones funcionales del servicio. La matriz separa quién puede hacer qué sobre cada recurso; no trata “autenticado” como un rol universal.

2. 2. Revisión de controles y amenazas

2.1. Autenticación

SessionService normaliza usuario, compara BCrypt y usa hash ficticio para desconocido, registra intentos, emite 32 bytes aleatorios para token/CSRF y persiste hashes SHA-256. Revalida identidad activa, revocación y expiración/inactividad; logout revoca. SessionCookie usa HttpOnly, SameSite=Lax y Secure configurable. Por fuente existe una limitación por sujeto en 15 minutos; no se asume que registrar sourceKey implemente un limitador global.

SEC-02 registra la discrepancia "consecutivos" frente al conteo acumulado de fallos de la ventana. Primero confirmar política; después cambiar requisito o código con prueba de secuencia fallo-éxito-fallo. No inventar un bypass a partir de esa diferencia. Credencial válida determina identidad, no competencias ni acceso a una carrera.

2.2. Autorización

ScopeAuthorizationService comprueba usuario activo no técnico, asignación vigente, scope que contiene el solicitado, capacidad y conflicto no exceptuado. CareerAdministrationService distingue administración global y lectura por carrera, incluidos totales e historial; SelfAssessmentService evalúa PROCESS_MANAGE por carrera y visibilidad al consultar. Revisar cada ruta: UUID conocido no es permiso. Los candidatos de asignaciones/auditoría del antecedente securityOutputs son needs_validation y no se dan por resueltos o confirmados aquí.

2.3. Validación sintáctica y de negocio

Operación : POST sessions
Sintaxis/estructura : username/password obligatorios con longitudes DTO
Negocio y protección : Identidad habilitada, credencial, ventana de intentos
Resultado relevante : 201 / 400 / 401 / 429 según caso.

Operación : POST careers
Sintaxis/estructura : code/name/UUID/validFrom; límites 100/300; validUntil opcional

Negocio y protección : Unidad activa, código normalizado único, vigencia coherente, CAREER_ADMIN, CSRF

Resultado relevante : 201 / 400 / 403 / 409 / 422.

Operación : PATCH careers/{id}

Sintaxis/estructura : UUID, cuerpo completo editable e If-Match fuerte numérico

Negocio y protección : Revisión vigente, unidad/código válidos, capacidad y auditoría

Resultado relevante : 200 / 400 / 412 / 428 además de rechazos de ámbito/negocio.

Operación : POST processes

Sintaxis/estructura : Referencias y fechas con tipos/obligatoriedad

Negocio y protección : Career/unidad activas, período dentro de vigencia, versión publicada y scope

Resultado relevante : 201 PREPARATION; 400/403/404/409/422 según causa.

Operación : GET careers

Sintaxis/estructura : Filtros/página dentro de límites

Negocio y protección : Visibilidad y total autorizado

Resultado relevante : 200 o rechazo; no mezclar página válida con permiso a todos.

2.4. Errores, secretos y configuración

Handlers/writer retornan Problem Details con código y correlación; errores inesperados tienen descripción genérica y registro técnico. Las muestras anteriores muestran 400/401/403/404/409/412/428 y 204 sin cuerpo, pero no todas las rutas/500. No se certifica ausencia de secretos en todos los logs. El sobre académico aún no se aplica; eso es diferencia contractual, no prueba de vulnerabilidad explotable. SEC-04 identifica el desafío401 ausente sin inventar Bearer.

Se inspeccionaron `.gitignore`, ejemplo env, prod y workflow manual; valores de ejemplo/CI sintéticos no se clasifican como credenciales reales. El escaneo confiable de 1.091 archivos de texto rastreados, acotado por tamaño/exclusiones, buscó tres formatos de credencial y retuvo solo metadatos: cero coincidencias. Se revisaron nombres históricos .env/pem/key, sin coincidencias; no se escaneó todo el contenido histórico ni formatos arbitrarios. No abrir ni copiar archivos personales de credenciales para llenar evidencia.

2.5. Mitigación y priorización

Cada amenaza tiene control, P/I, mitigación y prioridad. El análisis AA4 utiliza exactamente la matriz de la guía: 1–2 Bajo, 3–4 Medio, 6 Alto, 9 Crítico. El modelo incluye escenarios con controles presentes, no solo debilidades. No hay nuevas vulnerabilidades confirmadas ni se asigna severidad de vulnerabilidad a needs_validation.

3. 3. Clínica, evidencias y ajustes

Actividad ACD4 : 1 Revisar incremento
Desarrollo / evidencia : Sección 1, fuentes F-01–12 y límites.

Actividad ACD4 : 2 Identificar activos
Desarrollo / evidencia : Matriz compartida A-01–08 y razones/impacto/acceso.

Actividad ACD4 : 3 Actores/confianza
Desarrollo / evidencia : Fronteras y matriz por capacidad/ámbito.

Actividad ACD4 : 4 Superficies
Desarrollo / evidencia : Sesión, rutas, URL/query/JSON/headers, configuración y DB; exclusiones explícitas.

Actividad ACD4 : 5 STRIDE
Desarrollo / evidencia : T-01–09 pertinentes, sin forzar una categoría en una ruta inexistente.

Actividad ACD4 : 6 Matriz
Desarrollo / evidencia : Activo, causa/condición, P/I, riesgo de escenario y controles.

Actividad ACD4 : 7 Autenticación
Desarrollo / evidencia : Sesión/hash/expiración/invalidación y política pendiente.

Actividad ACD4 : 8 Autorización
Desarrollo / evidencia : Matriz de operaciones y scopes; lectura/administración no equivalentes.

Actividad ACD4 : 9 Entradas
Desarrollo / evidencia : Tabla sintaxis frente a negocio con fuentes concretas.

Actividad ACD4 : 10 Errores
Desarrollo / evidencia : Estados, Problem Details, correlación y vacío del sobre.

Actividad ACD4 : 11 Secretos/config
Desarrollo / evidencia : Metadatos de escaneo, configuración y límites de historia.

Actividad ACD4 : 12 Riesgos API

Desarrollo / evidencia : BOLA potencial, volumen/listados, permisos y configuración.

Actividad ACD4 : 13 Mitigaciones

Desarrollo / evidencia : Una o más por amenaza; ubicación/prueba en SEC/VT.

Actividad ACD4 : 14 Prioridad

Desarrollo / evidencia : Justificación diferenciada, sin todos altos/críticos.

Actividad ACD4 : 15 Revisión cruzada

Desarrollo / evidencia : CRUZADA-04-01 preparada; falta otro integrante/equipo y observación auténtica.

Actividad ACD4 : 16 Ajustes

Desarrollo / evidencia : CF-04-01 y trazabilidad preparados; no se inventa parche ejecutado.

Guion de socialización: mostrar C4/DFD y activos; elegir T-02 y T-05; seguir endpoint→control→test; explicar autenticación/autorización; revisar SEC-02; pedir observación sobre scope, lista/total y límites; registrar responsable/fecha/decisión/cambio. Una revisión asistida no equivale a revisión cruzada humana.

A. Incremento SIGEAC — Activos, amenazas y controles

Base común ACD4/APE4/AA4. Alcance: sesión, catálogo y preparación/consulta de procesos de Semana 3; identidad y auditoría como dependencias. Carga de evidencias, recuperación de cuenta e integraciones externas no forman parte del incremento seleccionado. No afirmar que estén ausentes de todo el producto por quedar fuera de este análisis.

A.1. Activos y confianza

ID : A-01

Activo / importancia : Identidades, credenciales y hash de contraseña

Acceso esperado : Usuario para autenticarse; gestión por capacidad y ámbito definidos

Impacto de exposición, alteración o pérdida : Suplantación y pérdida de acceso. No devolver contraseña/hash en API.

ID : A-02

Activo / importancia : Cookie SEC_SESSION, token CSRF y hashes de sesión

Acceso esperado : Navegador titular; backend valida/revoca

Impacto de exposición, alteración o pérdida : Secuestro de sesión o acciones falsificadas. El token opaco no es JWT.

ID : A-03

Activo / importancia : Catálogo de unidades/carreras y revisiones

Acceso esperado : CAREER_ADMIN global para cambios; CAREER_READ según ámbito para consulta

Impacto de exposición, alteración o pérdida : Datos inconsistentes, decisiones basadas en carrera incorrecta e historia perdida.

ID : A-04

Activo / importancia : Procesos, período y versión fijada

Acceso esperado : Gestor con PROCESS_MANAGE en carrera; consulta según permisos del proceso

Impacto de exposición, alteración o pérdida : Preparación ilegítima o información de ámbito ajeno. No equivale a acreditación.

ID : A-05

Activo / importancia : Auditoría y correlación

Acceso esperado : Servicio para registrar, auditor autorizado para consultar

Impacto de exposición, alteración o pérdida : Repudio, privacidad y pérdida de investigación de incidentes.

ID : A-06

Activo / importancia : Configuración, secreto HMAC y credenciales DB

Acceso esperado : Operador autorizado, fuera de Git

Impacto de exposición, alteración o pérdida : Acceso indebido, alteración de controles o indisponibilidad.

ID : A-07

Activo / importancia : API, CPU, memoria y DB

Acceso esperado : Clientes dentro de límites; operación por personal autorizado

Impacto de exposición, alteración o pérdida : Agotamiento y pérdida de disponibilidad.

ID : A-08

Activo / importancia : Código, contratos, pruebas y artefacto desplegable

Acceso esperado : Equipo por flujo versionado/revisado

Impacto de exposición, alteración o pérdida : Cambio no trazable, dependencia no reproducible o despliegue de artefacto equivocado.

Fronteras: F-01 cliente no confiable→API; F-02 sesión→autorización por objeto; F-03 controlador→aplicación/dominio; F-04 aplicación→DB/auditoría; F-05 operador/configuración→p F-06 repositorio/artefacto→despliegue. Autenticado no significa administrador ni acceso universal.

```
flowchart LR
  c[Cliente no confiable] -->|F01 HTTP JSON cookie headers| f[Filtro de sesion y
  ↪  CSRF]
  f -->|F02 identidad no es permiso| api[API]
  api -->|F03| app[Aplicacion y permisos de objeto]
  app --> dom[Dominio]
  app -->|F04| db[(PostgreSQL principal)]
  app --> audit[Auditoria]
  cfg[Operador y configuracion] -->|F05| f
  git[Codigo y artefacto versionado] -->|F06| api
```

A.2. Escala de planificación

Probabilidad 1 Baja, 2 Media, 3 Alta; impacto 1 Bajo, 2 Medio, 3 Alto. Producto 1–2 Bajo, 3–4 Medio, 6 Alto, 9 Crítico, como pide AA4. Estos valores priorizan **esce-**

narios del modelo, no prueban vulnerabilidades ni asignan severidad a hipótesis no validadas. Las valoraciones son cualitativas del análisis, pendientes de revisión cruzada, sin medición estadística.

A.3. Matriz de amenazas

ID / STRIDE : T-01 Spoofing

Activo / frontera / escenario : A-01/02, F-01; adivinar credenciales y reutilizar sesión

Causa o condición razonable : Credencial comprometida o automatización; no se presume bypass

Control existente / evidencia : BCrypt, token aleatorio de 32 bytes, hashes, ventana de intentos, expiración/revocación; SessionService y SessionCookie

P : 2

I : 3

P×I / nivel de escenario : 6 Alto

Mitigación y prioridad : Mantener controles y verificar credencial inválida, expiración y revocación; ensayar protección ante automatización acotada en sandbox. Alta por impacto en identidad; explotación no demostrada.

ID / STRIDE : T-02 Elevation / Disclosure

Activo / frontera / escenario : A-03/04, F-02; consultar o alterar recurso ajeno

Causa o condición razonable : Omisión futura de autorización por objeto o ámbito mal configurado

Control existente / evidencia : ScopeAuthorizationService y servicios de carrera/proceso comprueban capacidades/ámbito; UUID no es permiso

P : 1

I : 3

P×I / nivel de escenario : 3 Medio

Mitigación y prioridad : Pruebas lector A/objeto B, lista/total/detalle, cuenta técnica; asegurar denegación en cada ruta. Media; hay controles fuente, no BOLA confirmado en este recorte.

ID / STRIDE : T-03 Tampering

Activo / frontera / escenario : A-03, F-01/03; escribir sin intención o revisión válida

Causa o condición razonable : CSRF o edición con revisión vieja

Control existente / evidencia : Filtro propio verifica X-CSRF-TOKEN; ETag/If-Match y revisiones; APE3 HTTP-04/09/11

P : 1

I : 2

P×I / nivel de escenario : 2 Bajo

Mitigación y prioridad : Regresión y prueba de dos clientes; no aceptar control solo frontend. Baja residual de planificación, no aceptación formal del riesgo.

ID / STRIDE : T-04 Information Disclosure

Activo / frontera / escenario : A-02/06, F-05; cookie por transporte no protegido

Causa o condición razonable : Desplegar sin TLS o perfil equivocado

Control existente / evidencia : Default cookie-secure=false para local; prod=true y demo=false; configuración externa puede prevalecer

P : 1

I : 3

P×I / nivel de escenario : 3 Medio

Mitigación y prioridad : Exigir perfil/env efectivos, TLS y cookie Secure en despliegue. Media; no hay evidencia de exposición productiva.

ID / STRIDE : T-05 DoS

Activo / frontera / escenario : A-07, F-02/04; listado de procesos consume recursos en exceso

Causa o condición razonable : Repositorio carga todos los procesos antes del filtrado del servicio

Control existente / evidencia : JDBC list sin LIMIT; GET /processes sin parámetros de paginación; no se efectuó prueba de carga

P : 2

I : 2

P×I / nivel de escenario : 4 Medio

Mitigación y prioridad : Paginación/límites y filtrado autorizado en DB, contrato compatible y pruebas de total/ámbito. Media; agotamiento no reproducido.

ID / STRIDE : T-06 Repudiation

Activo / frontera / escenario : A-03/04/05, F-04; cambio crítico sin registro fiable

Causa o condición razonable : Falla de auditoría o política de retención/permisos incorrecta

Control existente / evidencia : Servicios transaccionales y AuditPort; historial de catálogo

P : 1

I : 3

P×I / nivel de escenario : 3 Medio

Mitigación y prioridad : Inyectar fallo en fixture y comprobar rollback; validar permisos de auditoría/retención. Media; no declarar atomicidad solo por @Transactional.

ID / STRIDE : T-07 Information Disclosure

Activo / frontera / escenario : A-06/08, F-05/06; secreto real versionado

Causa o condición razonable : Configuración local o credencial copiada al repositorio

Control existente / evidencia : .gitignore, env placeholders y CI sintética; escaneo acotado sin coincidencias de tres patrones

P : 1

I : 3

P×I / nivel de escenario : 3 Medio

Mitigación y prioridad : Gestión externa/rotación, revisión de diffs y ampliar escaneo si hay indicio; metadatos sin valores. Media; ausencia de coincidencias no certifica ausencia total.

ID / STRIDE : T-08 DoS / Spoofing

Activo / frontera / escenario : A-01/07, F-01; coste BCrypt distribuido por muchos sujetos

Causa o condición razonable : Límite por sujeto no establece un límite global de admisión

Control existente / evidencia : SessionService limita cuenta/ventana; registra sourceKey, sin inferir límite por IP de esa persistencia

P : 2

I : 2

P×I / nivel de escenario : 4 Medio

Mitigación y prioridad : Verificar control global/proxy con propietario; límites razonables sin sustituir bloqueo por cuenta ni perjudicar usuarios compartiendo IP. Media; no se ha demostrado agotamiento.

ID / STRIDE : T-09 Observación de interoperabilidad; no amenaza STRIDE afirmada

Activo / frontera / escenario : A-03/08, F-01; consumidor interpreta error incorrecto o pierde diagnóstico

Causa o condición razonable : Contrato común académico difiere del implementado; 401 sin desafío en muestra previa

Control existente / evidencia : Problem Details con código/correlación; no stack en cuerpo en muestras; AA3 propuesta de adaptación

P : 1

I : 1

P×I / nivel de escenario : 1 Bajo

Mitigación y prioridad : Acordar contrato, revisar WWW-Authenticate y validar cuerpos/headers; no inventar Bearer. No se clasifica como filtración ni bypass sin evidencia.

No se agrega una amenaza de archivos/SSRF/recuperación de cuenta sin ruta del recorte que la justifique. El modelo no agota el producto. Los siete registros needs_validation de securityOutputs/run-1 pertenecen a una revisión anterior más amplia; no se convierten en confirmados ni se consideran resueltos por estas tablas.

A.4. Permisos comprobables por capacidad y ámbito

Recurso / operación : POST sessions

Sin sesión : Credenciales válidas según política

Lector con ámbito : Autenticar su identidad

Administrador funcional de catálogo : Autenticar su identidad

Gestor de proceso : Autenticar su identidad

Cuenta técnica : Identidad técnica no implica capacidades funcionales

---

Recurso / operación : Consultar carrera/lista/historia

Sin sesión : Denegar

Lector con ámbito : CAREER_READ y carrera visible; totales filtrados

Administrador funcional de catálogo : CAREER_ADMIN según servicio global

Gestor de proceso : Solo si dispone también de lectura aplicable

Cuenta técnica : Servicio de catálogo rechaza actor técnico

Recurso / operación : Crear/editar/estado catálogo

Sin sesión : Denegar

Lector con ámbito : Denegar sin CAREER_ADMIN

Administrador funcional de catálogo : Permitir con validaciones, CSRF y revisión cuando corresponde

Gestor de proceso : PROCESS_MANAGE no concede CAREER_ADMIN

Cuenta técnica : Denegar

Recurso / operación : Preparar proceso

Sin sesión : Denegar

Lector con ámbito : Denegar sin capacidad

Administrador funcional de catálogo : CAREER_ADMIN por sí solo no habilita

Gestor de proceso : PROCESS_MANAGE y ámbito de carrera, carrera/unidad/modelo válidos

Cuenta técnica : Denegar

Recurso / operación : Consultar proceso

Sin sesión : Denegar

Lector con ámbito : Según capacidades y ámbito implementados

Administrador funcional de catálogo : No acceso universal por administrar catálogo

Gestor de proceso : Según permiso del proceso

Cuenta técnica : Denegar

Recurso / operación : Autorizar institucionalmente

Sin sesión : Fuera del incremento

Lector con ámbito : No inferir

Administrador funcional de catálogo : No inferir por rol técnico

Gestor de proceso : PROCESS_MANAGE no equivale a autoridad institucional

Cuenta técnica : No inferir

La matriz resume código visible; cada caso debe probarse con fixtures. No se asignan personas/órganos institucionales sin validación.

B. Hallazgos académicos, controles y trazabilidad — Semanas 4–5

Se diferencia **observación fuente comprobada**, **evidencia histórica de ejecución**, **riesgo potencial** y **vulnerabilidad confirmada mediante reproducción**. Esta revisión no establece nuevas vulnerabilidades confirmadas. Los puntajes siguientes pertenecen a escenarios de planificación AA4 y no son CVSS ni severidades de registros needs_validation.

ID : SEC-01

Activo / amenaza / causa : A-07 / T-05; cargar procesos completos antes de filtrar

Evidencia concreta : JdbcSelfAssessmentRepository.list selecciona sin LIMIT; SelfAssessmentService.list filtra luego

Estado de certeza : Mecanismo fuente comprobado; agotamiento potencial, no reproducido

P / I / resultado / nivel de escenario : 2 / 2 / 4 Medio: requiere volumen, afecta disponibilidad del listado

Control actual : Autenticación y filtrado de visibilidad, sin paginación declarada

Acción, ubicación y comprobación : Cambiar servicio/repositorio/contrato y cliente conjuntamente; paginar en DB conservando scope/total; VT-08, límite y prueba de ámbito.

ID : SEC-02

Activo / amenaza / causa : A-01 / T-01; política de intentos no coincide literalmente con RNF-003

Evidencia concreta : RNF-003 dice consecutivos; countFailures cuenta todos los fallos en ventana y no recorta tras éxito

Estado de certeza : Discrepancia fuente comprobada; efecto de política requiere confirmación y prueba

P / I / resultado / nivel de escenario : 2 / 2 / 4 Medio: secuencia razonable, puede limitar acceso legítimo; no es bypass probado

Control actual : Limitación por sujeto, auditoría y errores uniformes

Acción, ubicación y comprobación : Confirmar acumulados vs consecutivos; después corregir requisito o consulta/servicio y test fallo-éxito-fallo. No cambiar política

unilateralmente. VT-03.

ID : SEC-03

Activo / amenaza / causa : A-02/06 / T-04; transportar sesión sin condiciones de producción

Evidencia concreta : application.yml local false; application-prod.yml true; SessionCookie usa propiedad

Estado de certeza : Riesgo condicionado a despliegue; no exposición productiva comprobada

P / I / resultado / nivel de escenario : 1 / 3 / 3 Medio: exige configuración equivocada, comprometería sesión

Control actual : Perfil prod y flag Secure, HttpOnly/SameSite=Lax

Acción, ubicación y comprobación : Verificar configuración efectiva, TLS/proxy y cookie en entorno aislado; rechazo de demo/credenciales reales en imagen. VT-09.

ID : SEC-04

Activo / amenaza / causa : A-08 / T-09; 401 sin WWW-Authenticate

Evidencia concreta : AccessProblemWriter no lo establece; APE3 HTTP-01/21 no lo registró

Estado de certeza : Observación de protocolo apoyada por fuente/muestra previa; no explotación

P / I / resultado / nivel de escenario : 1 / 1 / 1 Bajo: impacto observado de interoperabilidad, sin bypass

Control actual : 401 y cuerpo seguro/correlación

Acción, ubicación y comprobación : Resolver desafío compatible con mecanismo elegido; probar header y no enumeración VT-01/02. No añadir JWT/Bearer por conveniencia.

ID : SEC-05

Activo / amenaza / causa : A-01/07 / T-08; admisión distribuida de intentos costosos

Evidencia concreta : SessionService cuenta por subject y calcula BCrypt; sourceKey registrado no equivale a throttling

Estado de certeza : Riesgo potencial; controles de proxy/operación no observados

P / I / resultado / nivel de escenario : 2 / 2 / 4 Medio: múltiples sujetos pueden aumentar coste, sin DoS demostrado

Control actual : Límite por cuenta y ventana; hash ficticio evita respuesta diferencial simple

Acción, ubicación y comprobación : Propietario debe confirmar límites globales; ensayo acotado con límites de CPU/tiempo, sin inundación. VT-10.

La prioridad de ejecución de controles de identidad T-01 es alta por el activo, aunque SEC-02/05 no sean vulnerabilidades explotadas confirmadas. No se clasifica todo como alto/crítico. Los niveles 1–2 Bajo, 3–4 Medio, 6 Alto y 9 Crítico se aplican exactamente como AA4.

B.1. Matriz SDD

Amenaza / hallazgo : T-01 / SEC-02/05

Requisito / criterio previo : AA-RF-01; AA-RNF-01/02; RNF-003; AC-AA-01/02

Componente / endpoint : Identidad; POST sessions

Control : BCrypt, ventana, sesión aleatoria revocable

Prueba / evidencia : SessionServiceTest existe; APE3 HTTP-02; VT-01–03 planificados

Corrección y estado : Confirmación de política y validación pendientes.

Amenaza / hallazgo : T-02

Requisito / criterio previo : AA-RF-04/07/12; AC-AA-06/13/24

Componente / endpoint : Catálogo/procesos; detalle/listados/mutación

Control : ScopeAuthorizationService, chequeo por objeto

Prueba / evidencia : CareerAdministrationServiceTest; VT-04/05 pendientes de nueva ejecución

Corrección y estado : Sin nueva omisión confirmada en este recorte; mantener regresión.

Amenaza / hallazgo : T-03

Requisito / criterio previo : AA-RF-08; AA-RNF-05; AC-AA-14/15

Componente / endpoint : PATCH careers

Control : CSRF y If-Match

Prueba / evidencia : APE3 HTTP-04/09–12; VT-06/07

Corrección y estado : Revisión secuencial previa; prueba concurrente pendiente.

Amenaza / hallazgo : T-04/07 / SEC-03

Requisito / criterio previo : AA-RNF-03; RNF-005; VC-AA-03

Componente / endpoint : Configuración/cookie/despliegue

Control : prod, env, .gitignore

Prueba / evidencia : Escaneo acotado y fuente; VT-09

Corrección y estado : Sin secreto real confirmado; TLS y entorno efectivo no comprobados.

Amenaza / hallazgo : T-05 / SEC-01

Requisito / criterio previo : AA-RNF-04/10; VC-AA-04/10

Componente / endpoint : GET processes, repositorio

Control : Filtro de ámbito; límites pendientes

Prueba / evidencia : Fuente; VT-08

Corrección y estado : Cambio compatible de paginación planificado, no implementado.

Amenaza / hallazgo : T-06

Requisito / criterio previo : AA-RF-13; AA-RNF-06/07; AC-AA-25

Componente / endpoint : Auditoría y mutaciones

Control : Transacción y registro

Prueba / evidencia : SelfAssessmentAuditServiceTest existe; VT-11

Corrección y estado : Inyección de fallo no ejecutada.

Amenaza / hallazgo : T-09 / SEC-04

Requisito / criterio previo : AA-RF-14; AA-RNF-10; AC-AA-26; HTTP-AA-01

Componente / endpoint : Handlers/writer; respuestas 400/401/403/404/409/500

Control : Problem Details, código/correlación

Prueba / evidencia : APE3 JSON y VT-01/12

Corrección y estado : Contrato universal y desafío pendientes; AA3 ADR propuesto, no aplicado.

B.2. Inventario de verificación a ejecutar en sandbox conforme

ID : VT-01

Caso y resultado que debe comprobarse : Sesión ausente: 401, cuerpo seguro, desafío válido según decisión

Fuente o prueba existente : SecurityConfiguration/AccessProblemWriter; prueba académica propuesta

Estado actual : Muestra previa 401; desafío ausente; nueva regresión sin ejecutar.

ID : VT-02

Caso y resultado que debe comprobarse : Credenciales válidas/incorrectas/desconocidas: éxito solo válido y fallo uniforme

Fuente o prueba existente : SessionServiceTest, unknownAndWrongCredentialsShareTheSameFailureCode

Estado actual : Test fuente existente; no se ejecutó en Semana 4.

ID : VT-03

Caso y resultado que debe comprobarse : Expiración antes/después de 30 min, revocación y secuencia de fallos

Fuente o prueba existente : SessionServiceTest; reloj controlado

Estado actual : No esperar 30 min ni manipular cuentas reales; nueva ejecución pendiente.

ID : VT-04

Caso y resultado que debe comprobarse : Lector A no obtiene carrera B ni total/lista ajenos

Fuente o prueba existente : CareerAdministrationServiceTest y prueba HTTP propuesta

Estado actual : Control fuente y prueba existente; sin nueva reproducción.

ID : VT-05

Caso y resultado que debe comprobarse : Lector o cuenta técnica no cambia catálogo

Fuente o prueba existente : Servicio + ScopeAuthorizationServiceTest

Estado actual : Nueva ejecución pendiente.

ID : VT-06

Caso y resultado que debe comprobarse : Mutación autenticada sin CSRF devuelve 403

Fuente o prueba existente : APE3 HTTP-04

Estado actual : Evidencia histórica, no campaña nueva.

ID : VT-07

Caso y resultado que debe comprobarse : DTO inválido 400; duplicado 409; If-Match ausente 428/viejo 412; fechas/relaciones inválidas

Fuente o prueba existente : APE3 casos y CareerControllerTest/CareerTest

Estado actual : Parcial histórico; reglas faltantes pendientes.

ID : VT-08

Caso y resultado que debe comprobarse : Página/límite/ámbito/total de procesos y recursos usados

Fuente o prueba existente : Contrato/servicio/repositorio a refinar

Estado actual : Sin paginación nueva ni carga ejecutada.

ID : VT-09

Caso y resultado que debe comprobarse : TLS/cookie efectiva, demo false, secretos externos y ausencia en logs/imagen

Fuente o prueba existente : Configuración prod y despliegue propuesto

Estado actual : Solo revisión estática; no despliegue observado.

ID : VT-10

Caso y resultado que debe comprobarse : Admisión de login con límites globales razonables

Fuente o prueba existente : Servicio y posible proxy del propietario

Estado actual : Sin load test, sin límite global comprobado.

ID : VT-11

Caso y resultado que debe comprobarse : Fallo de auditoría no presenta cambio crítico completado

Fuente o prueba existente : AuditPort, tests relacionados

Estado actual : Pendiente de fixture con fallo controlado.

ID : VT-12

Caso y resultado que debe comprobarse : 204 sin cuerpo, errores/correlación sin secretos; schema real aceptado

Fuente o prueba existente : APE3 HTTP-20 y errores; OpenAPI/AA3

Estado actual : Histórico parcial; sobre universal sin implementar.

B.3. Correcciones y revisión cruzada

Registro : CRUZADA-04-01

Amenaza / observación recibida : Pendiente de otro integrante/equipo identificado y fecha real

Decisión / mitigación / artefacto : Registrar qué cambia o por qué se mantiene, responsable, requisito/componente/endpoint y commit

Estado : No realizada ni atribuida.

Registro : CF-04-01

Amenaza / observación recibida : Pendiente de fallo de prueba o hallazgo validado

Decisión / mitigación / artefacto : Registrar antes→parche→después y evidencia reproducible

Estado : No implementada/verificada.

La corrección documental, el escaneo acotado y la preparación de tests/configuración sí están realizados; no sustituyen una mitigación funcional demostrada.

C. Fuentes compartidas — Semanas 4 y 5

C.1. Evidencia del repositorio

Relación y límite : Requisitos, AC y verificaciones. No inventar aprobaciones institucionales.

ID : F-02

Rutas desde la raíz / símbolo relevante : `backend/src/main/java/ec/edu/unl/sec/identityaccess/application/SessionService.java`, login/authenticateForRequest/logo `backend/src/main/java/ec/edu/unl/sec/identityaccess/infrastructure/SessionCookie.java`; `backend/src/main/java/ec/edu/unl/sec/identityaccess/infrastructure/SessionAuthenticationFilter.java`

Relación y límite : Sesión aleatoria, hashes, expiración, cookie y CSRF propio. No deducir ausencia de CSRF por deshabilitar el mecanismo estándar.

ID : F-03

Rutas desde la raíz / símbolo relevante : `backend/src/main/java/ec/edu/unl/sec/identityaccess/application/ScopeAuthorizationService.java`; `backend/src/main/java/ec/edu/unl/sec/identityaccess/infrastructure/SecurityConfiguration.java`; `backend/src/main/java/ec/edu/unl/sec/identityaccess/infrastructure/JpaIdentityAccessRepository.java`, countFailures

Relación y límite : Capacidad/ámbito y política de autenticación; countFailures no recorta tras éxito.

ID : F-04

Rutas desde la raíz / símbolo relevante : `backend/src/main/java/ec/edu/unl/sec/selfassessment/api/CareerController.java`; `backend/src/main/java/ec/edu/unl/sec/selfassessment/application/CareerAdministrationService.java`; `backend/src/main/java/ec/edu/unl/sec/selfassessment/domain/Career.java`; `backend/src/main/java/ec/edu/unl/sec/selfassessment/infrastructure/JdbcCareerCatalogRepository.java`

Relación y límite : Validación sintáctica/de negocio, normalización, unicidad, visibilidad, revisiones y auditoría.

ID : F-05

Rutas desde la raíz / símbolo relevante : backend/src/main/java/ec/edu/unl/sec/selfassessment/api/SelfAssessmentController.java; backend/src/main/java/ec/edu/unl/sec/selfassessment/application/SelfAssessmentService.java, list/create; backend/src/main/java/ec/edu/unl/sec/selfassessment/infrastructure/JdbcSelfAssessmentRepository.java, list

Relación y límite : Preparación y consulta; listado materializa sin LIMIT antes de filtrar. DoS no demostrado.

ID : F-06

Rutas desde la raíz / símbolo relevante : backend/src/main/resources/application.yml; backend/src/main/resources/application-prod.yml; backend/.env.example; .gitignore; .github/workflows/backend-ci.yml

Relación y límite : Perfil, parámetros, variables y CI manual con PostgreSQL/contraseña sintética. Ejemplos no equivalen a credenciales reales ni entorno desplegado.

ID : F-07

Rutas desde la raíz / símbolo relevante : backend/src/main/java/ec/edu/unl/sec/shared/api/ApiProblemHandler.java; backend/src/main/java/ec/edu/unl/sec/identityaccess/infrastructure/AccessProblemWriter.java; backend/src/main/java/ec/edu/unl/sec/shared/api/EntityTagSupport.java

Relación y límite : Errores seguros por intención, correlación y precondiciones. Revisar cuerpo real; no afirmar ausencia total de secretos por el nombre de handler.

ID : F-08

Rutas desde la raíz / símbolo relevante : backend/src/test/java/ec/edu/unl/sec/identityaccess/application/SessionServiceTest.java; backend/src/test/java/ec/edu/unl/sec/identityaccess/application/ScopeAuthorizationServiceTest.java; backend/src/test/java/ec/edu/unl/sec/selfassessment/application/CareerAdministrationServiceTest.java; backend/src/test/java/ec/edu/unl/sec/selfassessment/api/CareerControllerTest.java; backend/src/test/java/ec/edu/unl/sec/selfassessment/domain/CareerTest.java; backend/src/test/java/ec/edu/unl/sec/selfassessment/application/SelfAssessmentAuditServiceTest.java

Relación y límite : Tests existentes inspeccionados; no ejecutados nuevamente en Semanas 4–5.

ID : F-09

Rutas desde la raíz / símbolo relevante : documentos-academicos/APE3-semana-3/evidencias/http-resultados.json; pruebas-maven.json; http-intento-inicial.json; esquemas-resultados.json, bajo la misma carpeta

Relación y límite : Evidencia previa, 22 casos HTTP finales y 23 tests seleccionados. Muestras no son nuevas pruebas APE4, ni cubren toda seguridad.

ID : F-10

Rutas desde la raíz / símbolo relevante : `documentos-academicos/APE3-semana-3/arquitectura/workspace.dsl`; `documentos-academicos/APE3-semana-3/contratos/openapi-observado.yaml`; `openapi-objetivo.yaml` en la misma carpeta contratos; `documentos-academicos/AA3-semana-3/ADR-AA3-001-adaptacion-respuestas-api.md`

Relación y límite : C4, contrato real/objetivo y propuesta; sobre universal y DRF pendientes.

ID : F-11

Rutas desde la raíz / símbolo relevante : `securityOutputs/run-1/run-metadata.json`; `securityOutputs/run-1/findings.json`; `securityOutputs/run-1/coverage-ledger.json`

Relación y límite : Antecedente incompleto de otro commit; siete needs_validation, ninguno confirmado. No heredar conclusión ni severidad sin revalidación independiente.

ID : F-12

Rutas desde la raíz / símbolo relevante : `backend/pom.xml`; `.specify/memory/constitution.md`; `docs/adr/0001-modular-monolith.md`; `docs/adr/0018-catalog-contract-migration-compatibility.md`; `docs/technical/quickstart.md`

Relación y límite : Stack real Java21/Boot4.1.1 configurados, límites SDD/compatibilidad y operación existente. JDK local25 no redefine nivel de compilación.

Los archivos auxiliares nuevos de APE4/APE5 son propuestas de tests/configuración. Una comprobación de sintaxis de Python/YAML o un manifiesto no prueba autenticación, aislamiento, build, contenedorización ni despliegue.

C.2. Referencias oficiales consultadas

ID : O-01

Referencia : OWASP API1:2023 BOLA

Uso acotado : Revisar autorización por objeto, no solo sesión o UUID.

ID : O-02

Referencia : OWASP API4:2023 Resource Consumption

Uso acotado : Analizar límites de listado y coste de peticiones; no demuestra DoS del proyecto.

ID : O-03

Referencia : OWASP Authentication, Login Throttling / Responses

Uso acotado : Política por cuenta y respuesta uniforme; un registro de IP no equivale a admisión global limitada.

ID : O-04

Referencia : OWASP Session Management, Cookies / Expiration

Uso acotado : Revisar Secure/HttpOnly/SameSite y expiración; el entorno efectivo importa.

ID : O-05

Referencia : OWASP Authorization, Least Privileges / Every Request

Uso acotado : Denegar por defecto y verificar permiso de cada operación/recurso.

ID : O-06

Referencia : OWASP Secrets Management

Uso acotado : Gestión externa, alcance y ciclo de vida; no publicar los valores hallados.

ID : O-07

Referencia : OWASP Error Handling

Uso acotado : Diagnóstico con información pública acotada; separar registro técnico del cuerpo de respuesta.

ID : O-08

Referencia : OWASP Input Validation

Uso acotado : Validación sintáctica y semántica; no sustituye permisos.

ID : O-09

Referencia : Microsoft: amenazas STRIDE

Uso acotado : Estructura de amenazas pertinentes, sin forzar categorías vacías.

ID : D-01

Referencia : Docker Compose: services

Uso acotado : Configuración de servicio, límites, usuario/volúmenes; debe validarse con motor/versiones.

ID : D-02

Referencia : Docker Compose: networks, internal

Uso acotado : Red interna propuesta; no certifica sandbox o host.

ID : D-03

Referencia : Imagen oficial PostgreSQL, PGDATA

Uso acotado : Montaje PostgreSQL18 bajo /var/lib/postgresql; verificar imagen fijada y migración.

ID : D-04

Referencia : Spring Boot: Container Images

Uso acotado : Dockerfile/Buildpacks como opciones; página consultada identifica Boot4.1.2, no actualiza el POM4.1.1.

ID : D-05

Referencia : pytest: skip y xfail

Uso acotado : Una omisión es limitación, no test satisfactorio.

ID : H-01

Referencia : RFC9110, §§9/15.5.2; RFC9457

Uso acotado : Semántica HTTP, desafío401 y Problem Details; sobre académico distinto. Revisadas en actividades previas.

Estas fuentes guían el análisis; no se copian listas OWASP como hallazgos. Las inferencias locales y las valoraciones P/I se identifican en las matrices. No se investigaron CVE nuevas ni se hizo una SCA transitiva completa; no se certifican dependencias por no encontrar patrones de secretos.

C.3. Ejecución y límites

La habilidad de seguridad exige aislamiento OS con red/entorno/escrituras/recursos restringidos. Docker y Podman no estaban disponibles; WSL visible no acredita por sí solo una distribución aislada configurada. El proceso de auditoría queda incompleto por esa capacidad y no ejecuta código del target. Se conservaron metadatos de escaneo confiable de texto y antecedentes; no se realizaron ataques ni pruebas en servicios ajenos.

Las actividades académicas contienen propuestas y análisis completos hasta donde hay evidencia, pero las partes de implementación, reejecución y despliegue siguen pendientes. No se produjeron aprobaciones, correcciones funcionales, commits o feedback grupal ficticios.

Bibliografía

[1] OWASP, “Authentication cheat sheet,” https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html.

[2] ——, “Authorization cheat sheet,” https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html.

[3] ——, “Api1:2023 broken object level authorization,” https://api-security.owasp.org/editions/2023/en/0xa1-broken-object-level-authorization/.

[4] Docker, “Compose services and networks,” https://docs.docker.com/reference/compose-file/services/.

[5] Docker Library, “Postgresql official image documentation,” https://raw.githubusercontent.com/docker-library/docs/master/postgres/README.md.

[6] Spring Boot, “Container images,” https://docs.spring.io/spring-boot/reference/packaging/container-images/index.html.

[7] IETF, “Rfc 9110 http semantics,” https://www.rfc-editor.org/rfc/rfc9110.html.

[8] pytest, “Skipping and xfail,” https://docs.pytest.org/en/stable/how-to/skipping.html.